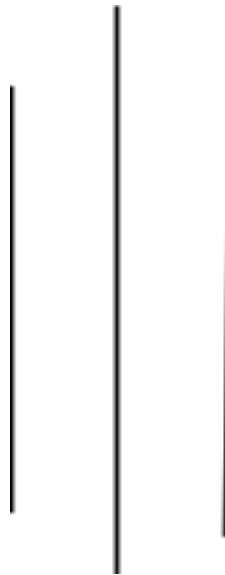


ORGANIZATIONAL CYBERSECURITY POLICY FRAMEWORK



Prepared by Bishika Pokharel

Course Title and Course Number: CSCE 3550, Section 004

Instructor's Name: Dr. Ali Zarafshani

Department Name: Computer Science Department

Institution Name: University of North Texas

Denton, Texas

Submission Date: 11/16/2025

Abstract

The evolving speed of digital infrastructure, cloud computing, mobile integration, and utilization of third-party technologies has been a major contributor to the susceptibility of organizations to cybersecurity risks, and to mitigate the significance of such risks to the operations of the organizations, systematic policy governance is the solution to restrain the risk and enhance the organizational resiliency of operations. The elaborate Organizational Cybersecurity Policy Framework, comprising ten security policies that aim to secure information resources, control the usage of systems, and adhere to industry standards, is utilized in this project. The policy-based research approach was applied in developing the project according to the authoritative resources of cybersecurity, such as NIST SP 800-37, NIST SP 800-53, ISO/IEC 27001, CIS Critical Controls, GDPR, HIPAA, and CISA guidelines. A uniformity, readability, and enforceability between the dissimilar contexts of operation was achieved by a similar format of creation of the policies: Purpose and Scope, Policy Statement, Applicability, and Authority.

The next framework is one of the approaches to managing the fundamental areas of security, comprising risk classification, data classification, access control, third-party governance, device and network security, data privacy, and acceptable use. The project illustrates that the information learned in the process of the practical application of the concepts of cybersecurity in the course of Certified in Cyber training and course-based research could be applied to the real-life environment, which would transfer the theoretical work to the formation of the governance documentation, which might be incorporated into the real-life organizational implementation. The project deliverables involve greater compliance with the regulatory requirements, a decrease in the unwarranted cyber threats, a good defense-in-depth strategy, and encouragement of a sustainable security-conscious culture. The policy framework provided, in its turn, will offer a model of scalable, flexible long-term adherence to cybersecurity, organizational resilience, and a steady enhancement of security posture.

Table of Contents

1. Introduction
2. Risk Categorization Policy
3. Data Classification Policy
4. Third Party Risk Management and Vendor Access Policy
5. Access Control for Devices and Data Protection Policy
6. Data Collection, Retention, and Disposal Policy
7. Network Infrastructure Devices Access Policy
8. Bring Your Own Device (BYOD) Policy
9. Client Privacy Policy
10. Employee Acceptable Use Policy
11. WiFi (Wireless Access Usage) Policy
12. Conclusion

Introduction

This project is aimed at developing a set of Organizational Cybersecurity Policy Framework which would comprise ten distinct security policies, which would be co-written with each other to provide a complete protection and governance framework. Each of the policies is formulated in the form of a shared format, viz. Purpose and Scope, Policy Statement, Applicability, Enforcement and Authority of making all the policies transparent, responsible, and duly placed at all the levels of the organization. These policies cover the highest priority of cybersecurity, such as risk management, data protection, access control, vendor management, privacy, and device security, as well as use of wireless networks.

This project require to choose the ten policies needed which were extremely developed and they were: Risk Categorization, Data Classification, Third-Party Risk Management and Vendor Access, Access Control for devices and Data Protection, Data Collection, Retention and Disposal, Network Infrastructure device Access, Bring Your own device, Client privacy, Employee Acceptable use and the Use of Wi-Fi (Wireless Access). The set of these policies provides expectations, restricts both operational and data related risks, and leads to conformance to the regulations and averts the behavior of users. By conducting this project, students will acquire practical knowledge on how to formulate policies in the area of cybersecurity according to the guidelines of the NIST, ISO/IEC, CIS Controls, HIPAA and GDPR that will give them an opportunity to generate successful entrants into the profession of cybersecurity governance and risk management.

Risk Categorization Policy

Purpose & Scope

The purpose of the Risk Categorization Policy is to establish a standardized methodology for identifying, evaluating, and categorizing risks associated with all organizational information systems, digital assets, and associated technologies to ensure the protection of confidentiality, integrity, and availability (CIA) of data and business operations (NIST, 2022). Risk categorization enables informed decision-making and ensures that the level of implemented security controls aligns proportionally with the potential impact of system compromise, data loss, or operational disruption (ISO, 2018). This policy applies to all enterprise-owned, leased, cloud-hosted, outsourced, or third party-managed systems and includes applications, network infrastructure, communication platforms, operational technology, and virtualized environments because unmanaged or unknown risk levels can lead to serious cybersecurity, regulatory, and financial consequences (ISACA, 2021). Establishing a structured and repeatable classification process ensures compliance with recognized national and international cybersecurity frameworks, including NIST SP 800-37, NIST SP 800-30, and ISO/IEC 27001, all of which

emphasize the necessity for risk-based governance as a foundational cybersecurity control (Stoneburner et al., 2002; ISO, 2018).

Policy Statement

It is the formal policy of the organization that every information system, data environment, application, hardware platform, and cloud-based service must undergo a documented and standardized risk categorization assessment before it may be purchased, installed, configured, deployed, accessed, or released for production use. All risk categorization activities must align with the NIST Risk Management Framework (SP 800-37) and utilize the Low, Moderate, or High impact rating model defined in NIST SP 800-30 to assess potential consequences to confidentiality, integrity, and availability. Categorization must be completed for all new systems, upgraded systems, legacy platforms, and externally hosted services, and must be reassessed annually or when significant system, architectural, or data-handling changes occur.

Categorization results must be recorded in a formal assessment report, approved by cybersecurity management, and stored in the organization's compliance repository. Systems categorized as Moderate or High risk must not proceed to implementation or operational status without a written Risk Treatment Plan that clearly identifies required mitigation actions, responsible parties, and completion deadlines. Security controls required as a result of categorization must be fully implemented, tested, and validated prior to granting operational authorization.

No exceptions, expedited deployments, undocumented classifications, or informal approvals are permitted under this policy, and any system not meeting categorization requirements will be suspended until full compliance is achieved.

Applicability

This policy applies to all individuals, departments, business units, and external partners responsible for designing, deploying, operating, accessing, transmitting, modifying, or disposing of digital assets and information systems, including full-time and part-time employees, contractors, consultants, interns, and technology vendors (Stair & Reynolds, 2020). It also applies to all technological environments, including on-premises data centers, hybrid and multi-cloud platforms, mobile computing, remote systems, Internet-of-Things (IoT) devices, virtual machines, and disaster recovery assets because risks may emerge in any environment where data is stored, processed, or transmitted (IBM Security, 2023). No system, regardless of function, data volume, operational duration, or perceived importance may bypass the categorization process; this includes test systems, prototypes, sandbox builds, and decommissioning infrastructures, as undocumented or informal systems are high-risk vectors contributing to shadow IT and supply-chain vulnerabilities (SANS Institute, 2023).

Enforcement

Compliance with this policy will be continuously verified through risk assessments, security audits, automated reporting, system monitoring, configuration review, and executive governance oversight, consistent with risk governance standards recommended by CISA (2023). Systems that fail to undergo risk categorization or those that operate outside approved classification thresholds will be immediately isolated, blocked from deployment, or suspended until corrective actions are completed (CISA, 2023). Personnel who fail to comply with required categorization procedures may be subject to formal disciplinary action, mandatory retraining, temporary system access revocation, or removal from assigned project responsibilities, depending on severity and frequency of violation (ISACA, 2021). In cases of deliberate negligence, concealment of system risks, falsification of risk documentation, or repeated refusal to implement mitigation controls, the organization reserves the right to pursue termination, contract cancellation, or external legal escalation, consistent with industry breach-response consequences (IBM Security, 2023). All non-compliance findings must be documented and reported directly to the Chief Information Security Officer and the Risk Management Committee for formal resolution.

Authority

The Chief Information Security Officer (CISO) holds primary authority for policy oversight, approval, audit coordination, and final risk categorization validation, as defined under NIST RMF governance roles (NIST, 2022). The Risk Management Committee and Executive Leadership Team (ELT) share authority for approving all risk-related policy revisions, reviewing High-risk asset findings, and validating final system categorization and mitigation outcomes (ISACA, 2021). System Owners, Data Custodians, and Security Administrators are jointly responsible for providing accurate system information, participating in assessments, and executing remediation tasks required for compliance (Stair & Reynolds, 2020). Authorized internal auditors and compliance personnel maintain authority to conduct inspections, require documentation, and mandate corrective actions without exception (ISO, 2018). No individual, department, or external partner may override authority for risk classification decisions without written authorization from executive governing officials.

Data Classification Policy

1. Purpose & Scope

The purpose of the Data Classification Policy is to establish a consistent framework for organizing and protecting organizational data based on its sensitivity, business value, and associated security or regulatory obligations. Proper classification ensures that data receives

protection proportional to its confidentiality, integrity, and availability requirements, helping prevent unauthorized access, disclosure, alteration, or destruction that could negatively impact operations, compliance, finances, or reputation (NIST, 2020). As modern organizations utilize cloud services, externally managed platforms, mobile technologies, and remote work models, it is critical to enforce standardized controls across the full data lifecycle, regardless of where or how the information is stored, processed, or transmitted (CSA, 2021; Catteddu & Hogben, 2020).

This policy applies to all organizational data formats—digital, physical, structured, and unstructured—such as documents, emails, multimedia files, legal contracts, application data, logs, archives, and printed materials. It remains enforceable across all work environments including on-premises systems, cloud platforms, hybrid networks, vendor-managed systems, and Bring-Your-Own-Device (BYOD) arrangements. All personnel, including employees, contractors, consultants, interns, vendors, and third-party service providers, are required to follow this policy without exception. The policy covers every stage of data handling from creation and storage to archival and disposal to ensure continuous adherence to compliance and cyber-risk mitigation standards (ISO/IEC, 2022).

2. Policy Statement

All organizational data must be classified at creation and reassessed whenever it is shared, modified, archived, or transferred to another system or storage environment. The organization will use a four-level classification system: Public, Internal Use, Confidential, and Restricted, with each tier defining handling expectations and required security controls (NIST, 2020). Public data may be openly disclosed, while Internal Use data must remain within the organization unless authorized. Confidential data requires controlled access, monitored sharing, encrypted storage, and secure transmission methods. Restricted data demands the strictest protections due to its connection to legal, contractual, or regulated information such as financial records, authentication credentials, consumer data, protected health information, or controlled unclassified data (FTC, 2022; IBM Security, 2023).

All confidential and Restricted data must be encrypted at rest and in transit, stored only in approved systems, and transferred using secure communication channels. Use of personal email accounts, consumer cloud services, or unauthorized removable media for any classified data is prohibited (CSA, 2021). Data deletion must follow secure destruction standards to prevent recovery. No data classification may be downgraded without formal authorization from the Data Governance Officer and CISO, ensuring oversight and regulatory alignment (ISO/IEC, 2022).

3. Applicability & Compliance Expectations

This policy applies to all individuals, business units, contractors, interns, vendors, consultants, and authorized third-party partners who create, store, transmit, or manage organizational data regardless of work location, device type, or employment status. Compliance is required in on-site, cloud-based, remote, and BYOD environments to minimize data loss, unauthorized disclosure, or regulatory violations. Users are responsible for understanding classification levels, applying correct labeling, preventing unauthorized sharing, and reporting suspected data mishandling or access violations immediately. Reclassification or downgrading of sensitivity levels is strictly prohibited unless approved by the Data Governance Officer after a documented assessment confirming reduced impact or legal obligation (ISO/IEC, 2022). Mandatory data protection and classification training must be completed annually to retain system access privileges, and individuals who fail assessments may be subject to remedial security training and supervised access restrictions.

4. Enforcement Overview

Compliance with this policy is enforced through automated Data Loss Prevention (DLP) systems, encryption verification reports, cloud security monitoring, internal audits, access control reviews, and user activity logging across all computing environments (CSA, 2021). Any violation, including mislabeling of data, use of unauthorized storage platforms, insecure file sharing, or bypassing encryption protocols, may result in corrective actions such as mandatory retraining, restricted access privileges, internal disciplinary measures, contract suspension, or termination for repeated or intentional violations. Incidents involving confidential or restricted data may also require external notification, incident reporting, regulatory review, legal escalation, and financial penalties where mandated under data protection laws. Severe violations may result in criminal liability or permanent access prohibition based on investigative findings (FTC, 2022; IBM Security, 2023).

5. Authority

The authority to approve, enforce, and maintain the Data Classification Policy resides with the Chief Information Security Officer (CISO), the Data Governance Officer, and the Executive Management Team. These roles are responsible for ensuring that classification standards remain aligned with regulatory requirements, industry frameworks, and organizational risk tolerance (ISO/IEC, 2022). The CISO oversees policy enforcement, incident response relating to data mishandling, and the implementation of technical safeguards such as encryption, access controls, and monitoring systems (NIST, 2020).

The Data Governance Officer is responsible for supervising data lifecycle processes including classification, retention, archival, and disposition to ensure compliance with laws such as GDPR, HIPAA, and state privacy regulations (GDPR, 2016). Executive Management provides strategic oversight, approves policy revisions, allocates necessary resources, and ensures cross-departmental compliance with data protection standards.

This policy will undergo formal review at least annually or after significant legal, technological, or operational changes to ensure continuous alignment with evolving compliance obligations and industry best practices (SANS Institute, 2021).

Third-Party Risk Management & Vendor Access Policy

Purpose & Scope

The purpose of the Third-Party Risk Management & Vendor Access Policy is to establish a formal, standardized, and risk-driven approach for assessing, approving, monitoring, and governing external parties who have access to organizational technology systems, data, networks, facilities, or business processes. This policy ensures that all vendors, contractors, cloud service providers, managed service providers, consultants, and outsourced personnel comply with cybersecurity, privacy, data governance, and regulatory requirements to protect the integrity, confidentiality, and availability of organizational assets (NIST, 2018). The scope of the policy covers all phases of the vendor life cycle, including selection, due diligence, procurement, onboarding, monitoring, contract renewal, and termination. It applies to all third-party engagements where digital integration, data sharing, system connectivity, physical access, or operational dependency exists, regardless of contract size, duration, location, or service level (CSA, 2021). This policy aligns with industry-recognized standards, including NIST SP 800-53, NIST SP 800-171, ISO/IEC 27036, and legal compliance frameworks such as GDPR, HIPAA, SOX, and the Federal Trade Commission (FTC) Safeguards Rule (FTC, 2022).

Policy Statement

All third-party entities must undergo documented cybersecurity risk assessment and due diligence prior to being granted access or entering contractual agreement with the organization. Vendors must provide verifiable evidence of strong information security controls, including one or more of the following, depending on service delivery: SOC 2 Type II audit report, ISO/IEC 27001 certification, NIST SP 800-171 compliance, PCI-DSS attestation, or Cloud Controls Matrix (CCM) compliance for cloud-based services (ISO/IEC, 2022; CSA, 2021). Every vendor must sign a Non-Disclosure Agreement (NDA) and a Data Protection Agreement (DPA) specifying security responsibilities, privacy obligations, breach notification timelines, and data

handling rules. Third-party access must follow least-privilege, role-based access control (RBAC), multi-factor authentication (MFA), secure connection protocols (such as VPN or encrypted API), and must not exceed contractual or functional need. All third-party systems integrated into organizational networks must undergo vulnerability and security compatibility review before activation and must agree to cooperate with penetration testing, incident investigation, and audit requests (NIST, 2020). Records of vendor status, risk tier, performance, and incidents must be maintained for continuous oversight.

Applicability

This policy applies to all employees, departments, and units involved in third-party initiation, review, provisioning, contracting, management, or termination, including executive management, procurement, information technology, cybersecurity, legal, risk management, audit, finance, and business owners responsible for vendor oversight (Catteddu & Hogben, 2020). It also applies to any third-party individual or organization with direct or indirect access to systems, applications, buildings, classified information, operational processes, or intellectual property.

Enforcement

Compliance with this policy will be monitored using contract audits, identity access logs, continuous monitoring tools, data-loss prevention systems, and annual vendor reassessment. Violations may result in immediate suspension of system access, contract termination, legal action, mandatory remediation plans, or notification to regulatory agencies depending on breach severity and legal requirements (IBM Security, 2023). Unapproved vendor engagement, data sharing, or system integration is strictly prohibited and may result in employee disciplinary action, including corrective training, written warning, or termination. All suspected violations must be reported to the Chief Information Security Officer (CISO) and the Security Risk Management Team.

Authority

The authority for approving, enforcing, reviewing, and updating this policy is assigned to the Chief Information Officer (CIO), Chief Information Security Officer (CISO), Legal Counsel, and the Director of Procurement. These roles are collectively responsible for ensuring alignment with regulatory requirements, business objectives, contractual frameworks, cybersecurity standards, and risk management best practices (ISO/IEC, 2022).

Access Control for Devices & Data Protection Policy

Purpose & Scope

The purpose of the Access Control for Devices & Data Protection Policy is to ensure that all devices accessing organizational information systems, networks, or data repositories are managed, authenticated, monitored, and protected using security controls that prevent unauthorized access, data misuse, system compromise, or confidentiality breaches (NIST, 2020). This policy ensures compliance with industry-recognized cybersecurity standards and aligns with organizational risk management, zero-trust architecture, and privacy protection requirements. The policy applies to all organizational devices, including desktops, laptops, servers, mobile devices, tablets, external storage media, virtual machines, cloud-managed endpoints, Internet-of-Things (IoT) devices, and remote-access equipment utilized for business operations (Microsoft, 2023). It also applies to data stored, processed, or transmitted across on-premises environments, cloud platforms, hybrid systems, and remote work infrastructures.

Policy Statement

All individuals accessing organizational data or information systems must be authenticated, authorized, and monitored in accordance with the principle of least privilege (POLP), role-based access control (RBAC), and zero-trust security verification standards (SANS Institute, 2021). Users must only receive the minimum level of access required to complete their assigned duties. All privileged, administrative, and elevated accounts must use multi-factor authentication (MFA), strong password controls, session time-outs, and secure login methods. Devices used to access organizational systems must meet security baseline requirements including encryption, updated antivirus, approved software, current security patches, and compliance with mobile device management (MDM) configurations where applicable (IBM Security, 2023). Sharing accounts, passwords, encryption keys, or credentials is strictly prohibited, and the use of personal or unauthorized devices for storing or accessing organizational data is not allowed without written approval and security validation.

Additionally, confidential and restricted data must reside only on approved secure platforms with enforced encryption both in transit and at rest. All remote access activities must utilize a secure Virtual Private Network (VPN) and be monitored for anomalies. Access privileges must be reviewed at minimum semi-annually and immediately upon role change, termination, or contract completion. Any violation of data access rules or device protections must be reported immediately to the Information Security Office.

Applicability

This policy applies to all full-time and part-time employees, executives, contractors, third-party vendors, consultants, temporary workers, interns, remote personnel, and service providers who use devices to access organizational information systems, communication platforms, or data

storage environments. It also applies to any non-organizational devices temporarily granted access for approved business functions.

Enforcement

Compliance will be verified through continuous system monitoring, audit logs, endpoint management tools, identity access reviews, cybersecurity assessments, and device posture validation. Violations may result in restricted access, password resets, credential revocation, suspension of device privileges, mandatory retraining, formal disciplinary actions, termination of employment or contract, and legal or regulatory reporting where required (IBM Security, 2023). Any suspected unauthorized access attempts, credential misuse, or suspicious activity must be reported immediately to the Chief Information Security Officer (CISO) or Information Security Office.

Authority

The authority responsible for enforcing and maintaining this policy includes the Chief Information Security Officer (CISO), Chief Information Officer (CIO), IT Security Administration Team, and Executive Management, who are required to review the policy annually or when significant regulatory, technological, or organizational changes occur (NIST, 2020).

Data Collection, Retention & Disposal Policy

Purpose & Scope

The purpose of the Data Collection, Retention & Disposal Policy is to establish standardized and legally compliant procedures for collecting, storing, retaining, archiving, and permanently destroying organizational data to ensure confidentiality, integrity, and availability (CIA) throughout the full data lifecycle (NIST, 2020). This policy ensures that only essential data is collected, maintained for the minimum legal and operational duration, and securely disposed of to prevent unauthorized recovery, misuse, breaches, or regulatory violations (Reynolds & Stair, 2020). The policy applies to all forms of organizational data, including physical and electronic documents, cloud records, databases, backups, emails, system logs, removable media, printed copies, and archived storage. It also applies to on-premises, off-site, and cloud-hosted locations, including disaster recovery and business continuity systems (Microsoft, 2023).

Policy Statement

All organizational data must be collected only for legitimate business, operational, legal, or compliance purposes, and must not exceed what is necessary for stated objectives (GDPR, 2016).

Sensitive or confidential information, including protected health information (PHI), personally identifiable information (PII), student or client data, financial data, security keys, and proprietary research, must be encrypted in storage and transmission, stored on approved secure environments, and access must follow least-privilege rules. Data retention periods must comply with federal, state, industry, and contractual requirements such as HIPAA, FERPA, PCI-DSS, SOX, and legal hold procedures (IBM Security, 2023). Each department must maintain documented retention schedules defining how long specific records are retained and the justification for retention. Data disposal must be executed using approved sanitization and destruction methods to prevent reconstructing, decrypting, or restoring deleted records. Acceptable destruction methods include cryptographic erase, digital wipe, degaussing, shredding, pulping, or certified destruction services, aligned with NIST SP 800-88 media sanitization guidelines (NIST, 2020). Under no circumstances may sensitive records be disposed of in standard trash, unsecured recycling bins, or non-encrypted digital deletion methods. When data has expired according to legal, administrative, or contractual timelines, departments must document completion and obtain approval from Information Governance or Legal before destruction.

Applicability

This policy applies to all full-time and part-time employees, contractors, vendors, interns, consultants, and third-party service providers who create, store, transmit, or handle organizational data in any manner. It also applies to departments responsible for compliance, record management, legal services, IT services, cloud management, security operations, and external hosted partners (SANS Institute, 2021).

Enforcement

Compliance will be verified through automated data archival systems, retention reports, digital audits, compliance logs, storage monitoring systems, and annual governance reviews. Any unauthorized data deletion, excessive data retention, incorrect disposal practice, or insecure handling must be reported immediately to the Chief Information Security Officer (CISO) or Data Governance Office. Violations may result in mandatory retraining, IT access restriction, formal disciplinary action, contract termination, civil liability, or legal charges depending on severity and regulatory implications (IBM Security, 2023).

Authority

This policy is managed, approved, and enforced by the Chief Information Security Officer (CISO), Data Governance Officer, Records Management Office, and Legal Counsel, who are

responsible for periodic updates aligned with evolving technology, data protection laws, and regulatory mandates (Microsoft, 2023).

Network Infrastructure Devices Access Policy

Purpose & Scope

The purpose of the Network Infrastructure Devices Access Policy is to establish formal security, configuration, authorization, and monitoring controls for all organizational network infrastructure devices to prevent unauthorized access, misconfiguration, data interception, service disruption, and cybersecurity compromise (NIST, 2018). Network infrastructure devices serve as the backbone of organizational connectivity and include routers, switches, firewalls, wireless access points, VPN gateways, intrusion detection and prevention systems, network controllers, and cloud-managed networking platforms. Because these devices control network routing, segmentation, authentication, and encrypted communications, improper access controls or insecure configurations could result in severe operational, financial, and privacy impacts (Cisco, 2022). This policy applies to on-premises, cloud-hosted, hybrid, wireless, virtual, and remote-managed network infrastructures used for corporate, administrative, academic, IoT, and data-center operations.

Policy Statement

Access to network infrastructure devices must be strictly limited to authorized personnel with validated business, administrative, or security requirements, using least-privilege access (LPA), role-based access control (RBAC), and multi-factor authentication (MFA) (Microsoft, 2023). All administrative access must take place over encrypted management protocols (e.g., SSH, TLS, HTTPS, or secure VPN tunnels). Legacy or insecure protocols such as Telnet, FTP, TFTP, and HTTP are strictly prohibited unless isolated and approved for controlled testing environments. Network device passwords must follow approved complexity standards and must be stored only within secure, encrypted credential vaults. Default manufacturer passwords must be changed before device deployment, and shared or generic login credentials are prohibited (SANS Institute, 2021).

All network infrastructure devices must follow baseline configuration standards aligned with NIST SP 800-53, CIS Benchmarks, or Zero-Trust Architecture principles. Logs for administrative activity, system events, configuration changes, and failed access attempts must be enabled, protected from tampering, and forwarded to approved logging or SIEM platforms for continuous monitoring (NIST, 2018). Network segmentation must be used to separate production, guest, wireless, IoT, and privileged network environments. Physical access to

network devices must be secured using locked server rooms, badge access controls, surveillance systems, and restricted access lists. Backups of firmware and configurations must be performed regularly, encrypted, and stored in approved secure storage locations.

Any remote access for device administration must be approved in advance, time-bounded, logged, and restricted using privileged access management (PAM). Only organization-owned and security-managed devices may be used to administer network infrastructure. Unauthorized personal devices, removable media, or public networks must not be used to connect or administer network devices.

Applicability

This policy applies to full-time and part-time employees, network engineers, cybersecurity personnel, system administrators, third-party service providers, contractors, cloud management partners, and managed security service providers (MSSPs) who configure, monitor, maintain, or access network infrastructure systems (Cisco, 2022). No other personnel may access or modify network configurations without written approval.

Enforcement

Compliance will be monitored through automated logging, identity-access reviews, configuration audits, penetration testing, and network security assessments. Violations — including unauthorized configuration changes, credential sharing, or disabling of security controls — may result in disciplinary action, revocation of accounts, suspended administrative access, mandatory retraining, termination, contract cancellation, or legal referral depending on severity (IBM Security, 2023). Any suspicious activity must be immediately reported to the Chief Information Security Officer (CISO) or Security Operations Center (SOC).

Authority

This policy is authorized and governed by the Chief Information Security Officer (CISO), Chief Information Officer (CIO), and Network Security Management Team, who maintain responsibility for reviews, updates, and security compliance enforcement (Microsoft, 2023).

Bring Your Own Device (BYOD) Policy

Purpose & Scope

The purpose of the Bring Your Own Device (BYOD) Policy is to establish standardized rules, security requirements, and operational controls for the authorized use of personally owned devices—including smartphones, tablets, laptops, wearable technology, and any

internet-connected device—when accessing organizational systems, data, applications, or networks. The objective of this policy is to protect organizational information from unauthorized disclosure, malware threats, data leakage, and interception while enabling secure mobility and productivity (NIST, 2020). This policy applies to all personal devices used to process, transmit, or store organizational information regardless of ownership, location, or connection type, including remote work, travel, hybrid work environments, and guest usage (Microsoft, 2023).

Policy Statement

Only approved and registered personal devices may be used to access organizational data, systems, or communication platforms. All personal devices must be enrolled in the organization's Mobile Device Management (MDM) or Enterprise Mobility Management (EMM) system to ensure compliance with data protection, encryption, authentication, patching, and monitoring requirements (SANS Institute, 2021). Devices must be configured with supported operating systems, security software, multi-factor authentication (MFA), and screen-lock protections using PIN, password, or biometrics. Organizational data must be stored only in approved, encrypted applications or cloud platforms and must never be downloaded to local device storage, removable media, or personal cloud accounts (IBM Security, 2023).

Jailbroken, rooted, or otherwise modified devices that bypass manufacturer security protections are strictly prohibited. Users shall not install unauthorized software, use public untrusted Wi-Fi networks without an approved VPN, or share credentials and devices with family members or other individuals. In case of device loss, theft, or suspected compromise, users must immediately notify the Information Security Office, and the organization reserves the right to perform a remote wipe of organizational data or disable access if needed to protect sensitive information (NIST, 2020). Organizational data must be separated from personal data using secure containerization, preventing comingling, unauthorized transfer, or uncontrolled sharing (Microsoft, 2023).

Participation in the BYOD program is voluntary; however, users who opt-in must agree to monitoring, security compliance, and the organization's right to revoke BYOD privileges without notice if policy violations or risks are identified. All BYOD activities are subject to logging, risk assessment, and technical enforcement controls.

Applicability

This policy applies to all full-time employees, part-time employees, contractors, interns, vendors, remote workers, and temporary staff who connect personal devices to organizational resources, including email platforms, collaboration tools, cloud applications, messaging services, or internal

networks. It also applies to all departments that approve or manage device access and support services.

Enforcement

Compliance will be enforced through automated MDM monitoring, authentication logs, access reviews, and periodic device compliance scans. Violations may result in removal of device access, mandatory retraining, temporary or permanent suspension of BYOD privileges, disciplinary action, employment termination, or legal escalation depending on severity and impact (IBM Security, 2023). Unauthorized connection attempts, data sharing, or tampering with security controls will be considered policy violations. All incidents must be immediately reported to the Information Security Office or Chief Information Security Officer (CISO).

Authority

This policy is authorized and governed by the Chief Information Security Officer (CISO), Information Technology Director, and Executive Management, who are responsible for approving updates, reviewing compliance metrics, and ensuring alignment with regulatory, legal, and cybersecurity standards (SANS Institute, 2021).

Client Privacy Policy

Purpose & Scope

The purpose of the Client Privacy Policy is to ensure that all personal, confidential, sensitive, or proprietary information collected from clients is managed, processed, stored, shared, transmitted, and disposed of in accordance with applicable legal, regulatory, ethical, and contractual privacy standards. The goal is to protect clients from privacy violations, identity theft, unauthorized disclosure, discrimination, or misuse of personal information while maintaining organizational integrity and trust (GDPR, 2016). The scope of this policy applies to all client information processed through physical or digital means, including personally identifiable information (PII), financial records, protected health information (PHI), biometric data, educational information, intellectual property, business contracts, and digital communication records (HIPAA, 1996). This policy applies to data processed in all environments including on-premises systems, cloud platforms, remote access workstations, third-party vendor systems, and mobile access points.

Policy Statement

Client data must only be collected for authorized and legitimate business, legal, or service delivery purposes, and must be limited to the minimum amount necessary to complete required operations (Kim & Solomon, 2021). All client information must be classified, labeled, and

handled in accordance with the organization's data classification and access control standards. Access to client data must follow the principle of least privilege, role-based access control (RBAC), and strong authentication measures such as passwords and multi-factor authentication (MFA) (NIST, 2020). Sensitive and confidential client information must be encrypted both in transit and at rest using approved cryptographic methods. Client data must not be shared with unauthorized personnel, external partners, or vendors without written consent, legal requirement, or a valid business need documented through data-sharing agreements (DPA/BAA) when applicable.

Clients must be informed of their privacy rights, including the right to access, correct, restrict, or request deletion of their information to the extent permitted by law (GDPR, 2016). Client data may not be stored on personal devices, personal cloud accounts, or removable storage unless specifically authorized and secured according to corporate policies. Inappropriate viewing, copying, disclosing, downloading, emailing, printing, photographing, or storing client information outside of approved secure systems is strictly prohibited (HIPAA, 1996). All employees must complete annual privacy and security training prior to handling any client data.

Applicability

This policy applies to all full-time and part-time employees, contractors, interns, temporary workers, consultants, volunteers, students, and third-party service providers who have access to, process, or manage client information in any capacity (Scholl et al., 2020). This includes all departments such as information technology, administrative support, business services, service delivery teams, legal, marketing, and customer support.

Enforcement

Compliance will be monitored through privacy audits, access log reviews, incident reporting systems, and automated data monitoring tools. Any suspected privacy violation, accidental disclosure, unauthorized access, or potential breach must be reported immediately to the Chief Privacy Officer (CPO) or Information Security Office. Violations may result in disciplinary action including retraining, written warning, suspension, removal of system access, termination of employment or contract, regulatory reporting, civil penalties, and possible criminal prosecution depending on severity (IBM Security, 2023).

Authority

This policy is authorized, reviewed, and enforced by the Chief Privacy Officer (CPO), Chief Information Security Officer (CISO), and Legal Compliance Office. These authorities oversee policy alignment with privacy regulations, internal audit results, and emerging privacy risks (NIST, 2020).

Employee Acceptable Use Policy

Purpose & Scope

The purpose of the Employee Acceptable Use Policy (AUP) is to establish clear rules, responsibilities, and guidelines for the ethical, secure, and lawful use of organizational information systems, digital assets, communication tools, networks, and computing devices. This policy is designed to prevent misuse, data breaches, operational disruptions, cyberattacks, insider threats, and legal or regulatory violations related to inappropriate or unsafe technology usage (Whitman & Mattord, 2022). The scope of this policy includes all organizational technologies such as computers, mobile devices, servers, cloud platforms, applications, email systems, VoIP, wireless networks, collaboration platforms, and remote-access systems used for business operations. The policy applies to local, cloud, hybrid, on-site, and remote work environments and prohibits the use of unauthorized software, hardware, or network tools (SANS Institute, 2021).

Policy Statement

Employees and authorized users must utilize organizational information systems and technology resources strictly for approved business activities aligned with professional, ethical, legal, and contractual obligations. Users must protect all assigned system accounts, passwords, authentication tokens, and encryption keys, and must never share or disclose credentials to any unauthorized individual (NIST, 2020). Technology resources must not be used for activities such as: accessing inappropriate or offensive content; unauthorized software installation; bypassing security controls; hacking, cracking or exploiting vulnerabilities; using personal cloud storage for work data; conducting political campaigning; engaging in harassment or discrimination; or performing any illegal or unethical activities (Kim & Solomon, 2021).

All data and content created, stored, transmitted, or processed using organizational systems are considered organizational property, and users must not expect personal privacy. Organizational monitoring tools, endpoint protection, and automated logging systems may be used to track usage, detect anomalies, and investigate suspicious activity (IBM Security, 2023). Users must immediately report security incidents, phishing attempts, lost devices, malware infection, or accidental data exposure to the Information Security Office.

Applicability

This policy applies to all full-time and part-time employees, contractors, interns, temporary workers, vendors, volunteers, consultants, remote staff, and third-party partners who access or utilize organizational systems, devices, or data. It applies to both organizational-owned

equipment and any approved personal device used under BYOD or remote-access authorization (Whitman & Mattord, 2022).

Enforcement

Compliance will be monitored through system logs, automated monitoring systems, network filters, and periodic technology usage reviews. Violations of this policy may result in progressive disciplinary actions, including verbal or written warnings, mandatory retraining, suspension of access privileges, device removal, termination of employment or contract, financial liability, and legal prosecution depending on severity and intent (IBM Security, 2023). Activities involving data compromise, harassment, intellectual property theft, or cybercrime may be reported to law enforcement or regulatory authorities. All incidents must be reported to the Chief Information Security Officer (CISO) or designated IT security authority.

Authority

This policy is authorized by the Chief Information Officer (CIO), maintained by the Chief Information Security Officer (CISO), and overseen by Human Resources (HR) and the Information Security Governance Committee. These authorities reserve the right to modify, suspend, or update this policy based on legal, regulatory, or technological requirements (NIST, 2020).

Wireless Access (Wi-Fi) Policy

Purpose & Scope

The purpose of the Wireless Access (Wi-Fi) Policy is to establish security, authentication, configuration, and usage requirements for all wireless networks and devices accessing the organization's information systems to ensure confidentiality, integrity, and availability of network resources (NIST, 2019). Due to the increased risk of unauthorized interception, eavesdropping, spoofing, and rogue access points, wireless networks must be configured and monitored using industry-approved encryption, authentication controls, and network segmentation to mitigate cybersecurity threats (Cisco, 2022). This policy applies to all wireless infrastructure including organization-owned access points, guest networks, IoT wireless devices, remote hotspots, and cloud-managed Wi-Fi systems across all facilities, campus networks, and remote work environments. Additionally, this policy applies to all employees, contractors, vendors, students, interns, consultants, and any approved user connecting organizational devices or BYOD endpoints to wireless services.

Policy Statement

All wireless networks must utilize secure encryption protocols such as WPA2-Enterprise or WPA3 and must never operate using deprecated security standards including WEP, WPA, or unsecured open authentication (NIST, 2019). Wireless access must require unique user authentication, multi-factor authentication (MFA) where applicable, and 802.1X network access control (NAC) for enterprise environments. Users must only connect to authorized and approved Wi-Fi networks, and the creation of unauthorized wireless hotspots, personal routers, ad-hoc peer-to-peer networks, or tethering without written approval is strictly prohibited (SANS Institute, 2021).

All wireless access must be logically segmented into securely managed virtual networks based on user classification such as internal corporate, restricted/privileged user, BYOD/employee mobile, guest, administrative, and IoT device networks. Restricted or sensitive operational systems must never rely solely on wireless access unless protected by additional encryption and monitoring controls (Cisco, 2022). Device connections must follow least-privilege principles, and wireless network broadcast SSIDs should be concealed when used for administrative or privileged accounts. Wireless intrusion detection systems (WIDS) or wireless intrusion prevention systems (WIPS) must be enabled for rogue access point detection, spoofing identification, and unauthorized activity mitigation.

Users must not transmit, store, or access confidential or restricted information over public Wi-Fi or unsecured hotspots unless protected by a secure virtual private network (VPN) approved by the Information Security Office (Microsoft, 2023). Devices must comply with endpoint protection measures such as approved antivirus, automatic patching, and firewall activation while connected to the organization's Wi-Fi. Wireless logs, access records, and authentication sessions must be retained and reviewed for incident investigation and security auditing.

Applicability

This policy applies to all employees, IT and security staff, students, administrative personnel, contractors, vendors, partners, researchers, and authorized visitors using either organization-owned or approved personal devices. It applies to all buildings, facilities, satellite offices, indoor and outdoor access points, and remote or hybrid network usage scenarios (NIST, 2019).

Enforcement

Compliance will be monitored through network monitoring tools, periodic penetration testing, automated security alerts, configuration audits, and wireless network scanning. Violations including unauthorized network creation, connection to prohibited access points, bypassing

security controls, or using compromised wireless credentials will result in disciplinary actions ranging from access restriction to termination, legal reporting, or contract cancellation depending on severity (IBM Security, 2023). All violations must be reported immediately to the Information Security Office or the Chief Information Security Officer (CISO).

Authority

This policy is authorized and overseen by the Chief Information Security Officer (CISO), Chief Information Officer (CIO), and Network Infrastructure Administration Team, responsible for periodic updates and enforcement to align with technology, regulatory, and cybersecurity changes (SANS Institute, 2021).

CONCLUSION

The implementation of a formal cybersecurity policy framework strengthens operational security, reduces risk exposure, and establishes good cyber governance practices throughout the organization. These ten policies define standardized expectations across users, devices, networks, data, and third-party relationships, providing the foundation required for regulatory compliance and incident response readiness (ISO/IEC, 2022).

Security policy effectiveness requires ongoing enforcement, leadership support, staff awareness, and continuous improvement as threats evolve. Policy reviews will occur at minimum annually or following major technological, organizational, or regulatory changes. The organization commits to maintaining cybersecurity maturity through layered protection mechanisms, threat intelligence, training, and security culture development, ensuring continued alignment with risk management best practices and mission objectives (CISA, 2023).

REFERENCES

- CISA. (2023). Risk management and resilience guidance. <https://www.cisa.gov/>
- ISACA. (2021). Risk IT Framework for Governance and Risk Management. <https://www.isaca.org/>
- ISO. (2018). ISO/IEC 27001 Information Security Management Standard. International Organization for Standardization.
- NIST. (2022). Risk Management Framework (SP 800-37 Rev. 2). National Institute of Standards and Technology. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>
- SANS Institute. (2023). Risk assessment and categorization best practices. <https://www.sans.org/>
- Stair, R., & Reynolds, G. (2020). Principles of Information Systems (13th ed.). Cengage Learning.
- Stoneburner, G., Goguen, A., & Feringa, A. (2002). Risk Management Guide for Information Technology Systems (SP 800-30). National Institute of Standards and Technology.
- Cloud Security Alliance (CSA). (2021). Cloud Controls Matrix (CCM). <https://cloudsecurityalliance.org>
- Catteddu, D., & Hogben, G. (2020). Cloud Computing Risk Assessment. European Union Agency for Cybersecurity (ENISA). <https://www.enisa.europa.eu>
- Federal Trade Commission (FTC). (2022). Standards for Safeguarding Customer Information (Safeguards Rule). <https://www.ftc.gov>
- International Organization for Standardization (ISO/IEC). (2022). ISO/IEC 27036 — Information Security for Supplier Relationships. <https://www.iso.org>
- National Institute of Standards and Technology (NIST). (2018). Security and Privacy Controls for Information Systems (SP 800-53 Rev.5). <https://doi.org/10.6028/NIST.SP.800-53r5>
- National Institute of Standards and Technology (NIST). (2020). Protecting Controlled Unclassified Information (SP 800-171 Rev.2). <https://doi.org/10.6028/NIST.SP.800-171r2>
- IBM Security. (2023). Cost of a Data Breach Report. Retrieved from <https://www.ibm.com/security/data-breach>
- Microsoft. (2023). Zero Trust and Access Control Security Documentation. Retrieved from <https://learn.microsoft.com/security>

National Institute of Standards and Technology (NIST). (2020). Digital Identity Guidelines (SP 800-63-3).<https://doi.org/10.6028/NIST.SP.800-63c>

SANS Institute. (2021). Identity and Access Management Best Practices. <https://www.sans.org>

Whitman, M., & Mattord, H. (2022). Principles of Information Security (7th ed.). Cengage Learning

Reynolds, G., & Stair, R. (2020). Fundamentals of Information Systems (9th ed.). Cengage Learning.

GDPR. (2016). General Data Protection Regulation (EU 2016/679). <https://gdpr.eu>

Cisco. (2022). Enterprise network security best practices. Cisco Systems. <https://www.cisco.com>

National Institute of Standards and Technology (NIST). (2018). Security and Privacy Controls for Information Systems (SP 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>

SANS Institute. (2021). Network security and administrative access best practices. <https://www.sans.org>

Whitman, M., & Mattord, H. (2022). Principles of Information Security (7th ed.). Cengage Learning.

GDPR. (2016). General Data Protection Regulation (EU 2016/679). <https://gdpr.eu>

HIPAA. (1996). Health Insurance Portability and Accountability Act (Public Law 104-191). <https://www.hhs.gov/hipaa>

Kim, D., & Solomon, M. (2021). Fundamentals of Information Systems Security (4th ed.). Jones & Bartlett Learning.

National Institute of Standards and Technology (NIST). (2020). NIST Privacy Framework: A Tool for Improving Privacy Risk Management. <https://www.nist.gov/privacy>

Scholl, M., et al. (2020). NIST SP 800-53 Rev.5: Security and Privacy Controls. <https://doi.org/10.6028/NIST.SP.800-53r5>

SANS Institute. (2021). Acceptable Use and Security Awareness Guidelines. <https://www.sans.org>

